

ROCAP: A Reference Ontology for Cybersecurity Attack Planning

Antoine Leblanc^{1,2} , Zequan Huang^{1,2} , Hervé Cholez³, Jacques Robin² ,
Sébastien Larinier² , Giancarlo Guizzardi⁴ , Ítalo Oliveira⁴ , Tiago Prince
Sales⁴ , Xavier Rousseau⁵ , Nourhène Ben Rabah¹ , and
Bénédicte Le Grand¹ 

¹ Center for Research in Informatics (CRI), University Paris 1 Panthéon-Sorbonne, France
{antoine.leblanc, zequan.huang, nourhene.ben-rabah,
benedicte.le-grand}@univ-paris1.fr

² Engineering School of Informatics, Electronics and Automation (ESIEA), France
{jacques.robin, sebastien.larinier}@esiea.fr

³ Luxembourg Institute of Science and Technology, Luxembourg
herve.cholez@list.lu

⁴ Semantics, Cybersecurity, and Services Group, University of Twente, The Netherlands
{i.j.dasilvaoliveira, g.guizzardi, t.princesales}@utwente.nl

⁵ Gatewatcher, France
xavier.rousseau@gatewatcher.com

Abstract. Cybersecurity is a constantly-evolving domain, driven by the rapid emergence of new vulnerabilities and the continuous expansion of novel technological environments. Amidst this complexity, Security Operations Center (SOC) analysts must continuously assess the risks threatening their infrastructure by reconstructing attack scenarios from scattered signals. Cybersecurity ontologies support this by modeling core concepts and structuring Cyber Threat Intelligence data, yet existing proposals suffer from limited reuse beyond their original use-case and, critically, do not represent the attack plan as an entity that exists independently of the traces it produces. We propose the *Reference Ontology for Cybersecurity Attack Planning (ROCAP)*, which is grounded in the Unified Foundational Ontology (UFO) and aligned with MITRE's *de facto* industry standards. By formalizing the attack plan as an intentional structure, ROCAP is designed to be reused and adapted across the evolving landscape while easing interoperability with operational workflows. We demonstrate its practical utility for SOC analysts by answering Competency Questions derived from *ISO/IEC 27005* and *NIST CSF 2.0*.

Keywords: Cybersecurity · Ontology · Attack Planning · Risk Assessment · Security Operation Center.

1 Introduction

Security Operations Center (SOC) analysts need to assess the risks threatening the Information and Communication Technology (ICT) infrastructure

under their protection, in order to choose the most efficient countermeasures—a decision grounded in the system’s resources, their vulnerabilities, and predefined attack scenarios. To do so, they must reconstruct attack scenarios from scattered signals observed across heterogeneous tools [39], at the intersection of risk and attack-planning reasoning.

Cybersecurity ontologies have emerged as the preferred approach [19]: they integrate narrow-scope tools at the conceptual rather than syntactic level, structure historical *Cyber Threat Intelligence (CTI)* data, and establish a shared communication framework. Attack trees and attack graphs also decompose an attacker’s goal into ordered steps, but as instance-level artifacts tailored to one assessment they lack foundational grounding, exhibiting ambiguous terminology and limited semantic interoperability [28]. The limitations below therefore concern reference ontologies specifically, not attack-modelling techniques in general. A *first* limitation concerns expressive scope. While some ontologies model the causal chain of an attack—its stages, dependencies, and techniques—and sometimes its attacker’s motivation, none formally represents the *attack plan* as an entity existing independently of the traces it produces. This matters operationally: the same credential reuse through phishing may serve data exfiltration or long-term persistence, and the defensive response differs accordingly. Capturing intention as a mere motivation label is therefore insufficient; distinguishing these cases requires representing the plan as an intention *bound to* a structured specification of the intended course of action—its ordered steps and dependencies—against which a partial execution can be interpreted [6]. A *second*, orthogonal limitation [19] is the lack of reuse beyond the original use-case: no operational ontology dedicated to attack planning is grounded⁶ in a general-purpose foundational ontology such as the *Unified Foundational Ontology (UFO)* [13]—a structural flaw that limits consistency maintenance during evolution and extension, as shown for D3FEND [27].

We propose a *Reference Ontology for Cybersecurity Attack Planning (ROCAP)* grounded in UFO, bridging (i) theoretically-grounded reference ontologies—integrating and extending the UFO-based *COVER* [32] and *ROSE* [26]—and (ii) operationally-grounded industry standards—adapting *MITRE D3FEND*⁷ [18], *CAPEC* [22], and the *Unified Kill Chain (UKC)* [31]. Aligned with these standards to *ease* integration with SOC workflows, ROCAP is published as a FAIR-compliant [17] artifact⁸ and was co-designed with SOC analysts from a *Network Detection and Response (NDR)* vendor together with experts in cybersecurity standards and ontological engineering.

Our contributions are twofold. First, building on the planning concepts of UFO-C—the social and intentional layer of UFO—we provide a formal

⁶ A reference ontology is a well-structured representation of a part of reality, designed for knowledge exchange and reuse, while an operational ontology is its concrete implementation.

⁷ Which itself includes the MITRE digital asset ontology of attack targets and the MITRE ATT&CK taxonomy [36]

⁸ All complementary code, ROCAP model and documents can be found here: <https://github.com/AntoineLeblancFr/ROCAP>.

ontological definition of an attack plan that leverages the intentional dimension of cyberattacks, absent from current attack-planning ontologies. Second, adapting from industry-standard ontologies and taxonomies, we define a set of *mediating concepts* that bring operational artifacts and ontological commitments into a single coherent model.

We validate ROCAP’s practical utility from a SOC-analyst perspective through *competency questions* derived by a cybersecurity-standard expert from ISO/IEC 27005:2022 [16] and NIST CSF 2.0 [25], answered over a Prolog instantiation of a real-life BlackSuit ransomware APT campaign [38] and a manually generated alternative.

The remainder of the paper is organized as follows. Section 2 introduces the ontological baseline and the related work. Section 3 presents ROCAP, our proposed ontology. Section 4 validates it from a SOC perspective and Section 5 concludes.

2 Related Work on Cybersecurity Ontologies

2.1 Ontological Baseline: Well-grounded Ontologies

The Unified Foundational Ontology (UFO) [13], an ISO/IEC CD 21838-5 standard proposal, is a formal theory integrating formal ontology, cognitive psychology, and linguistics, providing domain-independent, reusable concepts for conceptual modeling. It is operationalized through OntoUML [8], a language implementing UFO’s axioms as a precise, visually expressive syntax. Several ontologies build on it, including security ontologies COVER and ROSE.

The Common Ontology of Value and Risk (COVER) [32] conceptualizes Value and Risk, the latter grounded in ISO 31000:2018 [15]. COVER disambiguates Risk under three scopes: a measurable quantity (Risk); a chain of events (Risk Event) impacting an agent’s goals (Risk Experience); and the relationship ascribing a risk quantity to uncertain future experiences (Risk Assessment).

The Reference Ontology for Security Engineering (ROSE) [26] reuses and refines COVER for ISO 31000:2018 security. It refines the Risk Experience with an Attack (an Action specializing Risk Event) and an Attacker (an agent whose Threat Capability creates Attacks).

2.2 Industry Cybersecurity Standard Ontologies and Taxonomies

Several institutional frameworks structure the cybersecurity knowledge that existing ontologies draw upon.

MITRE ATT&CK [36] is a taxonomy of adversary tactics and techniques observed in real-world intrusions, organized along a kill-chain-like matrix that has become the *de facto* reference vocabulary for describing attack behavior.

MITRE D3FEND [18] is an ontology defining defensive countermeasures to be applied complemented by its offensive counterpart—ATT&CK. D3FEND also introduces a sub-ontology of artifacts (physical or digital), as the basis for conceptualizing the relations between offensive techniques (ATT&CK) and defensive techniques (D3FEND), providing a solid reference for cyber risk treatment.

CAPEC (Common Attack Pattern Enumeration and Classification) [22], also from MITRE, complements ATT&CK at a lower abstraction level, cataloging attack patterns with prerequisites, consequences, and related weaknesses.

CVE (Common Vulnerabilities and Exposures) [23] provides a standardized identifier for publicly disclosed *vulnerability types*, while **CWE (Common Weakness Enumeration)** [24] classifies the underlying software *weakness types* that these vulnerability types specialize.⁹ Together, the CAPEC→CWE→CVE chain enables a traceable path from abstract attack patterns to concrete exploitable weaknesses.

None of these frameworks, however, formalizes the intentional dimension of an attack: they catalogue the available offensive techniques, the vulnerabilities that enable them, and the defenses that counter them, yet none addresses the rationale underlying an attacker’s choice of a specific technique sequence, nor the structure by which such a choice constitutes a coherent plan.

2.3 Cybersecurity Ontologies on Attack Planning

The formal representation of cybersecurity knowledge has produced a diverse landscape of ontologies and knowledge graphs, which we survey along four axes.

Foundationally-grounded proposals. Only PAPO [29] anchors its constructs in a foundational ontology, reusing the UFO-based COVER and ROSE to model attacker intentions in the phishing domain. It shows that UFO can support intentional reasoning about cyberattacks, but remains scoped to a single attack family and does not address multi-stage campaigns.

Attack-sequencing proposals without intentional grounding. Most of the literature models the structural side of plans through attack-dependency formalisms. MulVAL [30], the APT attack ontology [40], WAVED [1], ATT&CK-Ont [2], TAO [21], and DDoS-Ont [5] encode multi-hop precondition–effect or kill-chain dependencies across ATT&CK tactics; others capture them only implicitly (CSKG4APT [34], KG-Reasoning [9]) or not at all (APTont [37], RMO [35]). The object of formalisation is invariably the *attack graph*: the space of possible attack paths. Such formalisms answer *what could happen*, not *what a specific adversary has committed to*.

Intentional proposals without structured plans. CSKG4APT [34] captures APT-group motivations and intent levels, and the Zachman-based attribution framework [33] analyses attacker motivations geopolitically. These contributions rightly treat attacks as goal-directed, but represent the attacker’s intention only as an *end goal*—a motivation label satisfiable in many ways. Such a reading is legitimate in general, yet insufficient for *plan recognition*,

⁹ A weakness (CWE) is a general type of flaw in software code or design, whereas a vulnerability (CVE) is a more specific vulnerability type, bound to a particular product and version, that can be directly exploited to compromise a system. Neither is a particular: the actual vulnerability is the one borne by a concrete deployed system, which *instantiates* a CVE-catalogued type.

which requires a *closed* intention [6,11]: one whose satisfaction is bound to the instantiation of a specific, structured course of action. It is this binding—not the goal alone—that these proposals leave unaddressed.

Explicit planning proposals. Only three proposals explicitly invoke planning. NAPO [14,7] targets network attack planning from a military perspective but lacks foundational grounding and standards integration; Liu & Guo’s AG-PDO [20] treats a plan as a solver output on the defender side; and DDoS-Ont [5], despite its title *Attack Plan Detection*, encodes a conjunction of CAPEC-derived preconditions rather than an intentional structure.

A recent survey [19] identifies one structural reason for this fragmentation: the near-absence of foundational grounding. Our review reveals a second. Existing approaches capture either the attacker’s intention—a goal label—or the execution as observed events. What lies *between* is left unrepresented: the plan itself—the intention committing the attacker to a specific, structured course of action—which gives content to the goal and provides the blueprint against which executions can be compared. This is the gap ROCAP is intended to fill.

3 A Reference Ontology for Cybersecurity Attack Planning

ROCAP reuses and extends the conceptual modeling of **Value** and **Risk** in COVER, together with that of security engineering in ROSE, and by integrating the above-mentioned industry adopted ontologies and taxonomies. Specifically, we focus on *Advanced Persistent Threat (APT)*, a form of highly targeted, multi-stage cyber-attack conducted by well-resourced **Attacker** (ROSE), which represents one of the most impactful forms of cyber-threat in practice. From ROSE’s perspective, an APT campaign can be considered as a **Risk Experience** constituted by interrelated **Risk Events**. This focus enables us to precisely characterize an **Attacker**’s intention and action by introducing the notion of **Attack Plan** (*cf.* Section 3.1).

In the rest of this paper, we use the following OntoUML representation conventions. External concepts are prefixed (*e.g.*, **Agent** from UFO is referred as **UFO::Agent**), and concepts defined or refined by us are highlighted with a thicker border and have no prefix. The color denotes the corresponding UFO categorization: pink for object types, blue for intrinsic aspect types, orange for situation types, yellow for event types, green for relators and purple for higher-order types. The same principle applies to all sub-ontologies introduced in the remainder of this paper.

3.1 Attack Plan Definition

The attacker model. ROCAP adopts an intentional model of the adversary grounded in UFO-C, COVER and ROSE. A **ROSE::Attacker** is a **UFO::Agent** characterized by three intrinsic aspects that jointly determine its behaviour: (i) a **COVER::Threat Capability**, the disposition capturing what the attacker is *able* to do (skills, tooling, resources); (ii) **UFO-C::Beliefs**, mental states representing

the attacker’s subjective perception of the target environment—its infrastructure, deployed defenses, and user behaviour; and (iii) `UFO-C::Intentions`, commitments to achieving an *objective*, where an objective is the goal that constitutes the propositional content of an intention. These aspects relate as follows: following the belief–desire–intention account of practical reasoning [6], the attacker forms an **Attack Plan** as a *closed* intention directed at an objective, selecting—on the basis of its `UFO-C::Beliefs`—a structured course of action it believes feasible, whose execution is in turn bounded by its **Capability**. `UFO-C::Beliefs` thus constrain which plans are *envisaged*; capability constrains which are *executable*. `COVER::Threat Capability` is detailed within the risk-assessment sub-ontology (Section 3.3); here it suffices that it is a property of the same attacker that bears the intention.

The attack plan definition. In UFO-C, a **Plan** is an `UFO-C::Action Type` (or originally in [11] an `UFO-C::Action Universal`)—an `UFO-B::Event Type` whose instances are actions performed by an agent to satisfy an intention [11]. The temporal parts of such an instance—its individual steps—stand in `UFO-B::Historical Dependence`, a relation stronger than accidental precedence but weaker than strict causality [12], and the agent’s commitment to realizing a specific plan is a `UFO-C::Closed Commitment`. Two readings of “plan” are admissible: a plan as an `Action Type`, or a plan as an *intention to instantiate* such an `Action Type` [6]. We adopt the latter, intentional reading, as it is the one relevant to attack *planning*: it lets us represent the attacker’s commitment to a specific structured course of action as an entity that exists independently of whether that course is realized—so that partially observed, or entirely unexecuted, campaigns can still be reasoned about.

Accordingly, we define an **Attack Plan** as a closed intention, i.e., an **Intention** that is also a `UFO-C::Closed Commitment`. Such an intention is held by a `ROSE::Attacker`, constrained by its `UFO-C::Beliefs`,¹⁰ and its propositional content is a malicious goal. Such an intention is *based on* a distinct `UFO-C::Complex Action Type` that specifies the structured course of action to which the attacker commits. `UFO-B::Historical Dependence` orders the temporal parts of the *instances* of that type—the individual attack steps of an actual campaign—not the parts of the type itself. An `ROSE::Attack` is then an `UFO-C::Action`—an actual, intentional occurrence in the world—that *instantiates* the `UFO-C::Action Type` and thereby *manifests* the **Attack Plan**.

3.2 Attack Plan Modelling

Assets under Attack. In **Figure 1**, we present a UFO-based, COVER & ROSE-aligned conceptualization of the socio-technical system targeted by the `ROSE::Attacker`. We represent one socio-technical system as composed of many instances of **Business Asset** that each hold value for an organization and therefore qualify as `COVER::Objects At Risk`. A **Business Asset**

¹⁰ A `UFO-C::Belief` represents an intentional mental state of an agent that models their subjective perception of reality.

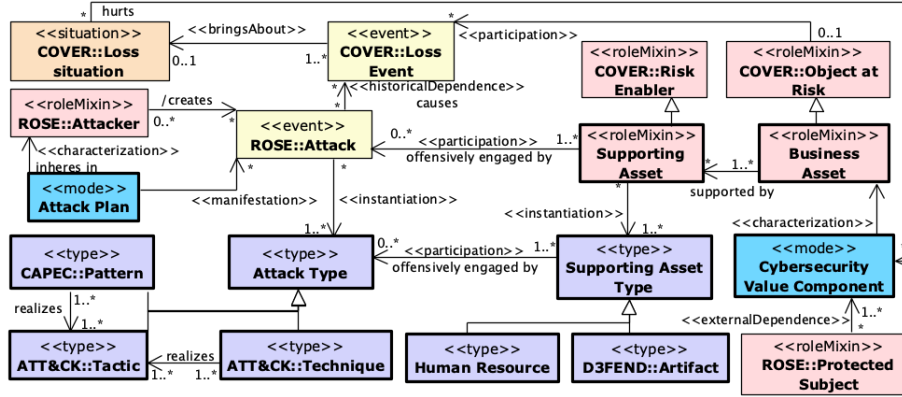


Fig. 1. The Attack sub-ontology of ROCAP

is an organizational component bearing value for the organization—every Business Asset is a `UFO::Endurant`¹¹ and can instantiate more specific types, such as Business Workflow. We introduce the Cybersecurity Value Component (a `UFO::Mode`) that characterizes a Business Asset with respect to a `ROSE::Protected Subject`'s concerns. We name it a *value component*, rather than a *security property* or *principle*, to mark its grounding in `COVER::Value`: confidentiality, integrity, and availability are modelled here not as free-standing properties but as the value dimensions a Business Asset holds for a Protected Subject. Specific components—such as Confidentiality, Integrity, and Availability—specialize it; each individual component (e.g., the confidentiality of a given patient record) inheres in the Business Asset and bears a value reflecting how strongly the Protected Subject requires it to be preserved. The bearer of these modes admits alternatives: the confidentiality level may instead be read as a belief of the Protected Subject—externally dependent on the asset's disposition to be exposed—or as a quality grading the protective capacities of the surrounding system, a design space analogous to the Trust/Trustworthiness distinction [3,4]. We retain inheritance in the Business Asset, its subject-relativity marked by the external dependence on the Protected Subject (Fig. 1), as our impact analysis attaches loss to the asset's value components; aligning with belief- and obligation-based readings is left to future work. Furthermore, a Business Asset is supported by Supporting Assets—a functional dependence rather than parthood [10]: to deliver its value to the `ROSE::Protected Subject`, a Business Asset requires instances of Supporting Asset functioning as such. The dependence is contingent, meaning that a Business Asset can exist without supporting assets (e.g., a newly chartered department), but cannot realize its value without them. A Supporting Asset is a role played by an Endurant: either a technical resource characterized by a `D3FEND::Artifact`—physical or not (e.g., a physical server, an operating system, a virtual machine, a deployed

¹¹ `UFO::Endurants` are individuals that persist in time while maintaining their identity, i.e., they are wholly present at any given moment of their existence.

business application)—or a **Human Resource**, a person in charge of the technical system. The payroll function, for instance, is supported by a deployed application, the server hosting it, and the administrators operating it.

A core design choice here is to decouple **COVER::Value** from **COVER::Vulnerability**. **Business Assets** hold **COVER::Value** for the organization through their **Cybersecurity Value Components**, whereas vulnerabilities attach at the supporting layer: **Supporting Asset** specializes **COVER::Risk Enabler** (ROSE) and therefore bears the **COVER::Vulnerabilities** that *characterize* a **Risk Enabler**. A **Supporting Asset** may thus bear one or more vulnerabilities (*e.g.*, unpatched software, or personnel with weak cyber awareness) that the **ROSE::Attacker** can exploit.

We acknowledge that a **Supporting Asset** such as a server also has value (*e.g.*, its monetary cost); we nonetheless attribute value at the **Business Asset** level and *distribute* a **Supporting Asset**'s value across the assets it supports. The reason is structural: our impact analysis reasons about loss through the **Cybersecurity Value Components** inhering in **Business Assets**, keeping the loss chain aligned with what the organization stands to lose; assigning intrinsic value to each **Supporting Asset**—the natural alternative—would double-count value already realized there. Symmetrically, a **Business Asset** bears **COVER::Vulnerabilities** only indirectly, through its **Supporting Assets**.

Attack Logic. To capture the **ROSE::Attacker**'s behavior, we align our model with the *de facto* **Tactics and Techniques** from [36]. An **ROSE::Attack** of a certain **Attack Type** is the manifestation of the **ROSE::Attacker**'s **COVER::Threat Capability** and **UFO::Intention** meeting a **COVER::Vulnerability** of a **Supporting Asset** (Section 3.3). The specialization of **Attack Type** is centered on **ATT&CK::Tactic**, which represents a complex **UFO::Event** type that achieves high-level adversarial goal (*e.g.*, **Initial Access**). An **ROSE::Attack** instantiates an **Attack Type** categorized along two complementary axes: **ATT&CK::Tactic**, the adversarial goal it pursues (*e.g.*, **Initial Access**), and **ATT&CK::Technique**, the means employed—each technique *realizing* one or more tactics. A **CAPEC::Pattern** addresses the same offensive mechanism at a more abstract level: both are event types—repeatable across occurrences—of which the **ATT&CK** and **CAPEC** catalogue entries are mere descriptions; a **Technique** types the observable behaviour, a **Pattern** the underlying mechanism.

We further make two claims to refine the granularity of impact analysis : (1) We assume that an **Attack** does not directly engage a **Business Asset**. Instead, it offensively engages a **Supporting Asset** by exploiting its **COVER::Vulnerabilities**; (2) The **Attack** subsequently causes a **COVER::Loss Event** which impacts the **Business Asset**. This brings about an unwanted **COVER::Loss Situation** (*e.g.* *data leak*) that hurts the **Cybersecurity Value Components** (*e.g.*, *confidentiality*) inhering in the impacted **Business Asset**, and thereby also hurts the **Intention** of a **ROSE::Protected Subject** (*cf.* Figure 1)

Attack Dependency. In **Figure 2** we define attack dependency by building on **Tactics** defined in **ATT&CK** [36], and the meta-tactics introduced in the Unified Kill Chain (UKC) [31]. UKC groups **Tactics** into three meta-Tactics—

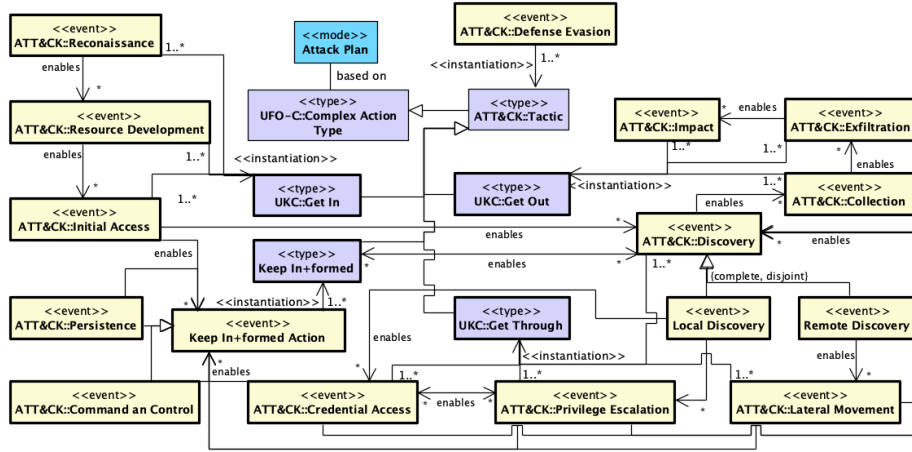


Fig. 2. The Attack Tactic dependency sub-ontology.

Get In, Get Through, and Get Out—which *subsume* ATT&CK::Tactic rather than aggregate its instances: a tactic such as Reconnaissance instantiates both ATT&CK::Tactic and Get In. Yet, UKC remains agnostic about temporal dependencies among the Tactics within each meta-tactic. Since UFO-B::Historical Dependence holds between individual events, the dependencies of Figure 2 cannot themselves be UFO-B::Historical Dependence relations between Tactics. Following the pattern of defined domain relations in ROSE, we introduce *enables* between event types: *enables*(*B*, *A*) holds when instances of *A* typically *historically depend on* some instance of *B*. Since *enables* relates first-order event types only, dependencies targeting the Keep In+formed meta-tactic go through Keep In+formed Action, a base event type specialized by its Tactics. Guided by the SOC analysts involved in the co-design to be compliant with real world APT campaigns, we propose several necessary adaptations to ATT&CK and UKC:

- We include all Tactics in our dependency modeling, except ATT&CK::Execution, which we treat as an internal part of other Tactics, rather than a standalone one.
- UKC places ATT&CK::Persistence and ATT&CK::Command and Control (C2) under UKC::Get In. However, during Get Through, new instances of these Tactics may be required at both host and network levels. We thus extend UKC’s tri-partite meta-Tactic structure by introducing a fourth called Keep In+formed to encompass both ATT&CK::Persistence and ATT&CK::C2.
- ATT&CK::Defense Evasion, which UKC places under Get In, is a *cross-cutting* Tactic: its instances serve to prevent detection by the defender. As this prevention relation targets the defensive sub-model, it lies outside the scope of Figure 2.
- We split ATT&CK::Discovery into two sub-tactics: Local Discovery and Remote Discovery. Local Discovery refers to discovery within a system

or network to which the **Attacker** already has access. **Remote Discovery** refers to discovery outside the **Attacker**’s current access zone.

Figure 2 orders these **Tactics** within each meta-Tactic. Two dependencies are worth noting, as they are fixed neither by ATT&CK nor by UKC. **Persistence** and **C2** are mutually enabling—trojan-based campaigns typically establish **Persistence** before **C2**, whereas web-shell intrusions reverse that order—and, in **Get Out**, both **Exfiltration** and **Impact** require **Collection**, which in turn depends on **Discovery**, since an attacker can only collect what it has already discovered.

3.3 Cybersecurity Risk Assessment

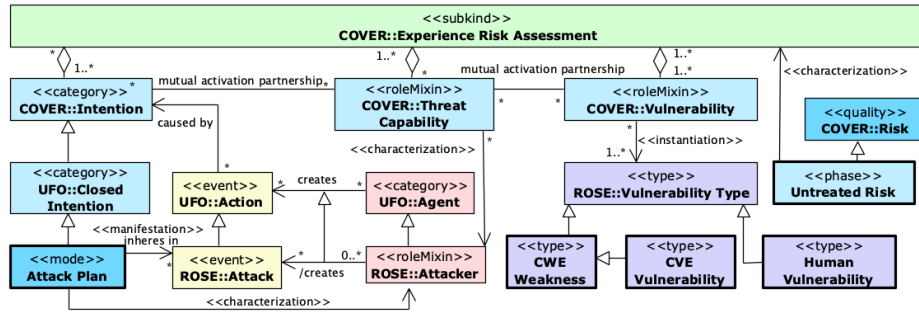


Fig. 3. The Cybersecurity Experience Risk Assessment sub-ontology

The initial risk assessment in ROSE and COVER is grounded in the **COVER::Risk Experience**, defined as the actual or potential interaction between an adversarial intent (**UFO::Intention**), a system **COVER::Vulnerability**, and an **ROSE::Attacker**.¹² In **Figure 3**, ROCAP introduces **Untreated Risk** being the **COVER::Risk** assessed through **COVER::Experience Risk Assessment**. Following COVER, we quantify **Untreated Risk** along likelihood (triggering and causal) and severity (the impact of a **Loss Event** on the **Cybersecurity Value Component**), reflecting the current risk exposure of a **Risk Subject** given the existing defenses.

Vulnerability Classification. Figure 3 models the **COVER::Vulnerability** inhering in the aforementioned assets as either a *technical* vulnerability—a **CWE::Weakness** type or a **CVE::Vulnerability**—or a *human* vulnerability, a bias arising from an individual’s dispositions or external influences [25], whereby the outcome of an action diverges from what the actor’s cognitive capability anticipated.

4 Validation

4.1 Methodology

To be practical and reusable, ROCAP should support the tactical and operational activities that security analysts perform around attack planning. Our validation

¹² More precisely its **COVER::Threat Capability**, a concept beyond the scope of this paper

proceeded in four iterative stages. First, the ontology was progressively reviewed with both expert groups, who assessed its conceptual completeness, suggested missing concepts (such as **Cybersecurity Value Component** or **Untreated Risk**), and validated its alignment with operational practice and cybersecurity standards. Second, cybersecurity requirements were systematically extracted from **ISO/IEC 27005:2022** and **NIST CSF 2.0** and mapped to ontology concepts. Third, Competency Questions (CQs) were derived through an expert-driven process involving two complementary groups: SOC analysts from Gatewatcher, contributing operational expertise on attack investigation and incident response, and information security standardization experts—including a member of the ISO/IEC JTC 1/SC 27 Luxembourg national committee—contributing risk-management expertise. The CQs were refined until consensus, ensuring both standard coverage and SOC-operational relevance. Finally, they were implemented as Prolog queries and evaluated against the BlackSuit ransomware and Long-Term Espionage scenarios.¹³ We present the most important CQs, related to **Attack Plan**, in Table 1.

4.2 Standards to Build Competency Questions

ISO/IEC 27005:2022 is the reference standard for information security risk management; its guidelines on identifying threats, vulnerabilities, and risk scenarios directly inform how an adversary operationalizes an attack. Crucially, it inherits the risk-management philosophy of ISO 31000:2018, already formalized in UFO terms by COVER and ROSE, letting us verify that ROCAP covers the standard’s requirements consistently with its underlying ontological commitments. **NIST CSF 2.0** complements it by structuring the full threat-management lifecycle: defensive outcomes—notably within *Identify*, *Govern*, and *Detect*—must mirror and anticipate an attacker’s tactical steps, and its outcome-driven rather than prescriptive character suits validating ROCAP’s operational aspects.

Table 1. Selection of Competency Questions (CQs) derived from ISO/IEC 27005:2022 and NIST CSF 2.0.

CQ ID & References	Competency Question
CQ4 (ISO §7.2.1, ID.RA-03)	What threat sources and actors are identified and associated?
CQ5 (ISO §7.2.1, ID.RA-02)	What capabilities, intentions, and objectives characterize an attacker?
CQ6 (ID.RA-02, DE.AE-07)	What attack types, techniques, and patterns characterize a given plan?
CQ7 (ISO §7.2.1, DE.AE, RS.AN)	Given a partial trace, which attack plans is the adversary carrying out?
CQ8 (ISO §7.2.1, DE.AE, RS.AN)	Can identically looking attacks be distinguished by the adversary’s goal?

4.3 Running Example: The BlackSuit Ransomware APT Campaign

We focus here on a Prolog implementation of ROCAP, two APT scenarios and the above competency questions. We chose Prolog for its expressivity to both represent

¹³ The complete traceability matrix linking standard requirements, ontology concepts, and competency questions is provided in the accompanying online repository: <https://github.com/AntoineLeblancFr/ROCAP>.

and execute complex, historical dependencies in attack planning. An OWL version of ROCAP is also available here. **APT Campaign.** We instantiate ROCAP with a simplified real-world scenario¹⁴ from a CTI report—*Fake Zoom Ends in BlackSuit Ransomware* [38]—in which the attacker compromises an organization through a malicious fake Zoom installer. As Figure 4 shows, the `blacksuitOperator` is characterized by `blacksuitPlan_bs`, an **Attack Plan** whose committed course of action decomposes into four **Closed Intentions**: `gainInitialFoothold_bs`, `maintainPersistent_bs`, `locateValuableData_bs`, and `exfiltrateAndEncryptDataToExtortVictim_bs`. This course of action is a **Complex Action Type**; its eight instantiating **Attack** occurrences—the individual steps, chained by **Historical Dependence**—manifest the plan. The first step offensively engages `johnDoe` (a person playing the **Supporting Asset** role), exploiting a **Human Vulnerability**; the remaining steps engage **Supporting Assets** of various types. Each such vulnerability ultimately drives the loss chain hurting `victimCorpITDepartment`’s value components, modelled at the type level in Figure 3. Traversing this path backwards, a SOC analyst can trace an adverse outcome to its originating vulnerability and threat source.

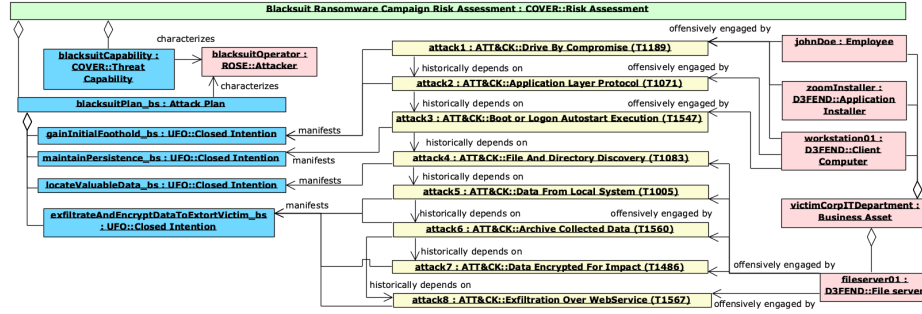


Fig. 4. Simplified Scenario from the BlackSuit Ransomware APT Campaign

An alternative espionage scenario. To demonstrate the operational value of plan reification, Figure 5 introduces a second **Attack Plan**: a manually generated *Long-Term Espionage scenario*. The second plan shares the first three steps with the BlackSuit campaign, but diverges at a distinct **Closed Intention**. While the shared-prefix mechanics are visible in Figure 5, anchoring the steps to separate intentions is what makes the plan/trace separation testable and allows the ontology to distinguish look-alike campaigns.

4.4 Answers to the Competency Questions

We now answer the competency questions of Table 1 on the running example, reporting for each what the corresponding Prolog query returns. To make the

¹⁴ For readability, Figure 4 depicts only the elements needed to answer the competency questions selected in this paper (Section 4.4); the complete instance diagram, including the loss chain (Loss Event, Loss Situation, Cybersecurity Value Component) and the borne vulnerabilities, is provided in the repository.

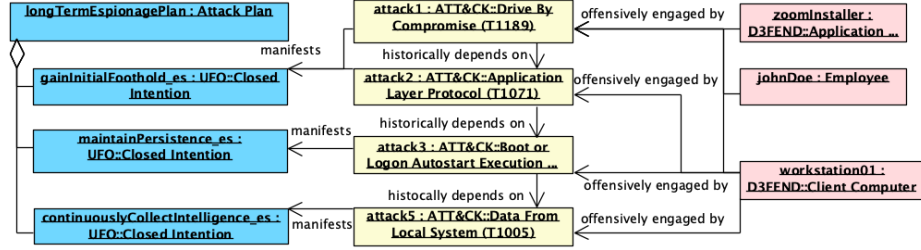


Fig. 5. Alternative Scenario from the BlackSuit Ransomware APT Campaign: Long-Term Espionage

reasoning transparent rather than merely report success, we then detail CQ7: we give its codification as a Prolog rule and walk through the resolution that produces its answer. We single out CQ7 because it is the question that most directly exercises the reification of the plan—reasoning over a partial execution to determine which plan an adversary is carrying out—and thus best illustrates the white-box reasoning the ontology affords.

Threat Sources and Actors (CQ4—CQ5). CQ4 identifies each `ROSE::Attacker` along with their associated `Attack Plan` and `COVER::Threat Capability`. In our execution, it successfully binds the BlackSuit operator to its *ransomware deployment capability* and *plan*, and the second *espionage attacker* to a *long-term access capability*. CQ5 expands this by returning the four reified `Closed Intentions` (from *initial foothold* to *encryption-based extortion*) that define the BlackSuit operator’s active objectives. This treats attacker objectives as structural ontological entities rather than plain-text labels.

Attack Plan (CQ6—CQ8). CQ6 maps the ordered attack steps of a plan to their corresponding `ATT&CK::Technique` types. CQ7 leverages the reification of the plan to reason over *partial* executions. Listing 1 gives its codification: each plan reifies the committed course of action it is based on as an ordered list of steps,¹⁵ carried by the plan’s `steps` attribute, and the rule succeeds through `append(Trace, Anticipated, Steps)` whenever the observed *Trace* is an ordered *prefix* of that sequence, binding *Anticipated* to the steps still to come.

Listing 1. Codification of CQ7 and the two candidate plans.

```

1 % CQ7: which plan is the adversary carrying out, given a partial trace?
2 % Succeeds when the observed Trace is an ordered prefix of the steps
3 % of the course of action the plan is based on.
4 cq7(Trace, cq7{plan:Plan, observed:Trace, anticipated:Anticipated}) :-
5     instanceOf(Plan, attackPlan),
6     attr(Plan, steps, Steps),
7     append(Trace, Anticipated, Steps).
```

¹⁵ For readability, steps are identified by their ATT&CK technique code; the repository uses named step individuals. The step list reifies the content of the plan’s `Closed Intention`—the course of action the attacker commits to.

The engine derives the answers in Listing 2 as follows. For the observed prefix `[t1189,t1071,t1547]`, the engine enumerates candidate plans via `instanceOf(Plan, attackPlan)` and retrieves each plan’s reified `Steps`. For `blacksuitPlan_bs`, `append` unifies the trace as a prefix of the eight-step sequence and binds *Anticipated* to `[t1083,t1005,t1560,t1486,t1567]`; on backtracking, the same holds for `longTermEspionagePlan`, binding *Anticipated* to `[t1005]`. Two solutions are returned—a state of *ambiguity*, each with its own anticipated continuation. When *File and Directory Discovery* (`t1083`) is additionally observed, `append` still succeeds for `blacksuitPlan_bs` (whose fourth step is `t1083`) but *fails* for `longTermEspionagePlan`, whose fourth step is `t1005`: the trace is no longer a prefix, so unification cannot proceed. The ambiguity collapses and `blacksuitPlan_bs` remains the sole answer.

Listing 2. CQ7 matching a partial trace against candidate **Attack Plans**.

```

1 % Ambiguous case: the observed techniques form a prefix shared by both plans
2 ?- cq7([t1189, t1071, t1547], Answer).
3 Answer = cq7{anticipated: [t1083, t1005, t1560, t1486, t1567],
4         observed: [t1189, t1071, t1547],
5         plan: blacksuitPlan_bs} ;
6 Answer = cq7{anticipated: [t1005],
7         observed: [t1189, t1071, t1547],
8         plan: longTermEspionagePlan}.
9 % Disambiguated case: t1083 belongs only to the BlackSuit plan
10 ?- cq7([t1189, t1071, t1547, t1083], Answer).
11 Answer = cq7{anticipated: [t1005, t1560, t1486],
12         observed: [t1189, t1071, t1547, t1083],
13         plan: blacksuitPlan_bs}.

```

CQ8 completes the picture by exercising the *intentional* layer: it isolates look-alike attacks that instantiate the same technique yet are anchored to separate, non-overlapping **Closed Intentions**. This is the distinction execution-oriented models cannot draw—two identical observations are told apart not by what is observed, but by the plan and intention they realize.

5 Conclusion

We presented ROCAP, a Reference Ontology for Cybersecurity Attack Planning grounded in UFO and integrating core ontologies (COVER, ROSE) with industry standards (D3FEND, CAPEC, Unified Kill Chain). By formalizing an **Attack Plan** as a **Closed Intention** bound to a **Complex Action Type**, ROCAP establishes a plan/trace separation that lets analysts reason about partially executed campaigns and distinguish identical early traces that diverge later—a capability unsupported by existing cybersecurity ontologies—and we validated it through competency questions derived from ISO/IEC 27005:2022 and NIST CSF 2.0 on a Prolog instantiation of the BlackSuit campaign. Future work will extend ROCAP into ROCADe (Reference Ontology for Cybersecurity Attack and *Defense* planning), supporting both defensive SOC and offensive red-teaming decision support, and fully align on UFO the concepts originating from D3FEND [27], particularly for automating risk analysis.

Acknowledgments. This work was supported by the French National Research Agency (ANR)(grant number ANR-23-CE39-0010) and the Luxembourg National Research Fund (FNR) (grant number INTER/ANR/23/18034502) under the ANCILE project. The authors thank the SOC analysts at Gatewatcher who participated in the co-design and validation of ROCAP.

Data Availability. All complementary code, ROCAP model and Competency Questions traceability can be found here: <https://github.com/AntoineLeblancFr/ROCAP>.

References

1. Akbar, K.A., et al.: The design and application of a unified ontology for cyber security. In: International Conference on Information Systems Security. pp. 23–41 (2023)
2. Akbar, K.A., et al.: The design of an ontology for ATT&CK and its application to cybersecurity. In: Proceedings of the Thirteenth ACM Conference on Data and Application Security and Privacy. pp. 295–297. ACM (2023)
3. Amaral, G., et al.: Towards a Reference Ontology of Trust, pp. 3–21 (2019)
4. Amaral, G., et al.: Trustworthiness requirements: The pix case study (2021)
5. Ansarinia, M., et al.: Ontology-based modeling of DDoS attacks for attack plan detection. In: International Symposium on Telecommunications. pp. 993–998 (2012)
6. Bratman, M.: Intention, Plans, and Practical Reason. Harvard University Press (1987)
7. Chan, P., et al.: An ontological knowledge base for cyber network attack planning. In: International Conference on Cyber Warfare and Security (2015)
8. Fonseca, C.M., et al.: Ontology-driven conceptual modeling as a service. *CEUR Workshop Proceedings* **2969** (2021)
9. Gilliard, E., et al.: Knowledge graph reasoning for cyber attack detection. *IET Communications* **18**(4), 297–308 (2024)
10. Guizzardi, G.: The Problem of Transitivity of Part-Whole Relations in Conceptual Modeling Revisited, pp. 94–109 (2009)
11. Guizzardi, G., et al.: Grounding software domain ontologies in the unified foundational ontology (UFO): The case of the ODE Software Process Ontology. In: Conferencia Iberoamericana de Software Engineering (2008)
12. Guizzardi, G., et al.: Towards ontological foundations for the conceptual modeling of events. In: Conceptual Modeling. pp. 327–341. Springer Berlin Heidelberg (2013)
13. Guizzardi, G., et al.: UFO: Unified Foundational Ontology. *Applied Ontology* (2022)
14. van Heerden, R., et al.: Using an ontology for network attack planning. *International Journal of Cyber Warfare and Terrorism* **6**(3), 65–78 (2016)
15. International Organization for Standardization: ISO 31000:2018 – risk management: Guidelines (2018)
16. International Organization for Standardization: ISO/IEC 27005:2022 – guidance on managing information security risks (2022)
17. Jacobsen, A., et al.: Fair principles: Interpretations and implementation considerations. *Data Intelligence* **2**(1-2), 10–29 (2020)
18. Kaloroumakis, P.E., Smith, M.J.: Toward a knowledge graph of cybersecurity countermeasures. Tech. rep., The MITRE Corporation (2021)
19. Leblanc, A., et al.: Rethinking Cybersecurity Ontology Classification and Evaluation: Towards a Credibility-Centered Framework. In: Enterprise Design, Operations, and Computing. pp. 284–299. Springer (2026)

20. Liu, Y., Guo, Y.: Towards real-time warning and defense strategy AI planning for cyber security systems aided by security ontology. *Electronics* **11**(24), 4128 (2022)
21. Luh, R., et al.: TAON: An ontology-based approach to mitigating targeted attacks. In: *Proceedings of the 18th International Conference on Information Integration and Web-Based Applications and Services*. pp. 303–312. ACM (2016)
22. MITRE Corporation: CAPEC – Common Attack Pattern Enumeration and Classification. <https://capec.mitre.org/>
23. MITRE Corporation: Common Vulnerabilities and Exposures (CVE). <https://www.cve.org/>
24. MITRE Corporation: Common Weakness Enumeration (CWE). <https://cwe.mitre.org/>
25. National Institute of Standards and Technology: The NIST Cybersecurity Framework (CSF) 2.0. Tech. Rep. NIST CSWP 29 (2024)
26. Oliveira, Í., et al.: An Ontology of Security from a Risk Treatment Perspective. In: *Conceptual Modeling – ER 2022*. pp. 365–379. Springer (2022)
27. Oliveira, Í., et al.: Boosting D3FEND: Ontological Analysis and Recommendations. In: *Proceedings of the FOIS 2023*. pp. 334–348 (2023)
28. Oliveira, Í., et al.: An ontological lens on attack trees: Toward adequacy and interoperability. In: *Formal Ontology in Information Systems*. vol. 409, pp. 151–165. IOS Press (2025)
29. Oliveira, Í., et al.: An ontological model of the phishing attack process. In: *Enterprise, Business-Process and Information Systems Modeling. BPMDS 2025, EMMSAD 2025*. vol. 558, pp. 274–289. Springer (2025)
30. Ou, X., et al.: MulVAL: A logic-based network security analyzer. In: *Proceedings of the 14th USENIX Security Symposium*. p. 113–128 (2005)
31. Pols, P.: The Unified Kill Chain. Tech. rep., Fox-IT and HAN University of Applied Sciences (2017)
32. Prince Sales, T., et al.: The Common Ontology of Value and Risk. In: *Conceptual Modeling. ER 2018*. Springer (2018)
33. Putrevu, V.S.C., et al.: A framework for advanced persistent threat attribution using Zachman ontology. In: *Proceedings of the 2023 European Interdisciplinary Cybersecurity Conference (EICC '23)*. pp. 34–41. ACM (2023)
34. Ren, Y., et al.: CSKG4APT: A cybersecurity knowledge graph for advanced persistent threat organization attribution. *IEEE Transactions on Knowledge and Data Engineering* **35**(6), 5695–5709 (2023)
35. Scarpato, N., et al.: Reachability matrix ontology: A cybersecurity ontology. *Applied Artificial Intelligence* **33**(7), 643–655 (2019)
36. Strom, B.E.: MITRE ATT&CK: Design and Philosophy. Tech. rep., The MITRE Corporation (2020)
37. Sun, L., et al.: APTKG: Constructing threat intelligence knowledge graph from open-source APT reports based on deep learning. *2022 5th International Conference on Data Science and Information Technology (DSIT)* pp. 01–06 (2022)
38. The DFIR Report: Fake Zoom Ends in BlackSuit Ransomware (March 2025), <https://thedfirreport.com/2025/03/31/fake-zoom-ends-in-blacksuit-ransomware/>
39. Vielberth, M., et al.: Security operations center: A systematic study and open challenges. *IEEE Access* **8**, 227756–227779 (2020)
40. Wang, F., et al.: Ontology-based APT attack detection and defense countermeasures. In: *International Conference on High Performance Big Data and Intelligent Systems (HDIS)*. pp. 27–33 (2022)